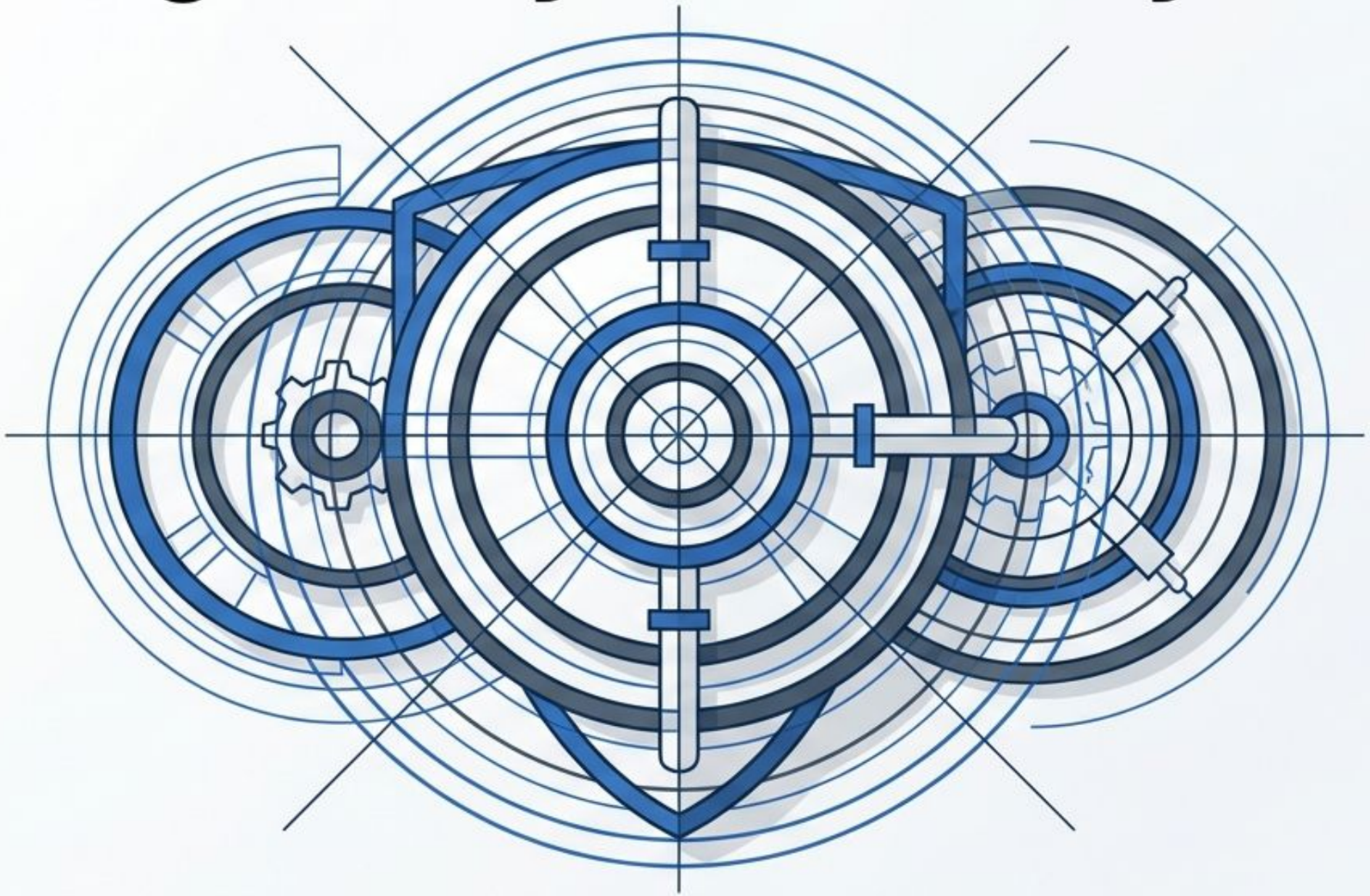
Navigating the Cybersecurity Lifecycle



Attacks, Strategies, and Legal Frameworks

Prepared By : Er, Sharat Maharjan

DEFINING THE THREAT LANDSCAPE

THREAT LANDSCAPE: The collective set of threat actors, attack vectors, and vulnerabilities facing an organization.

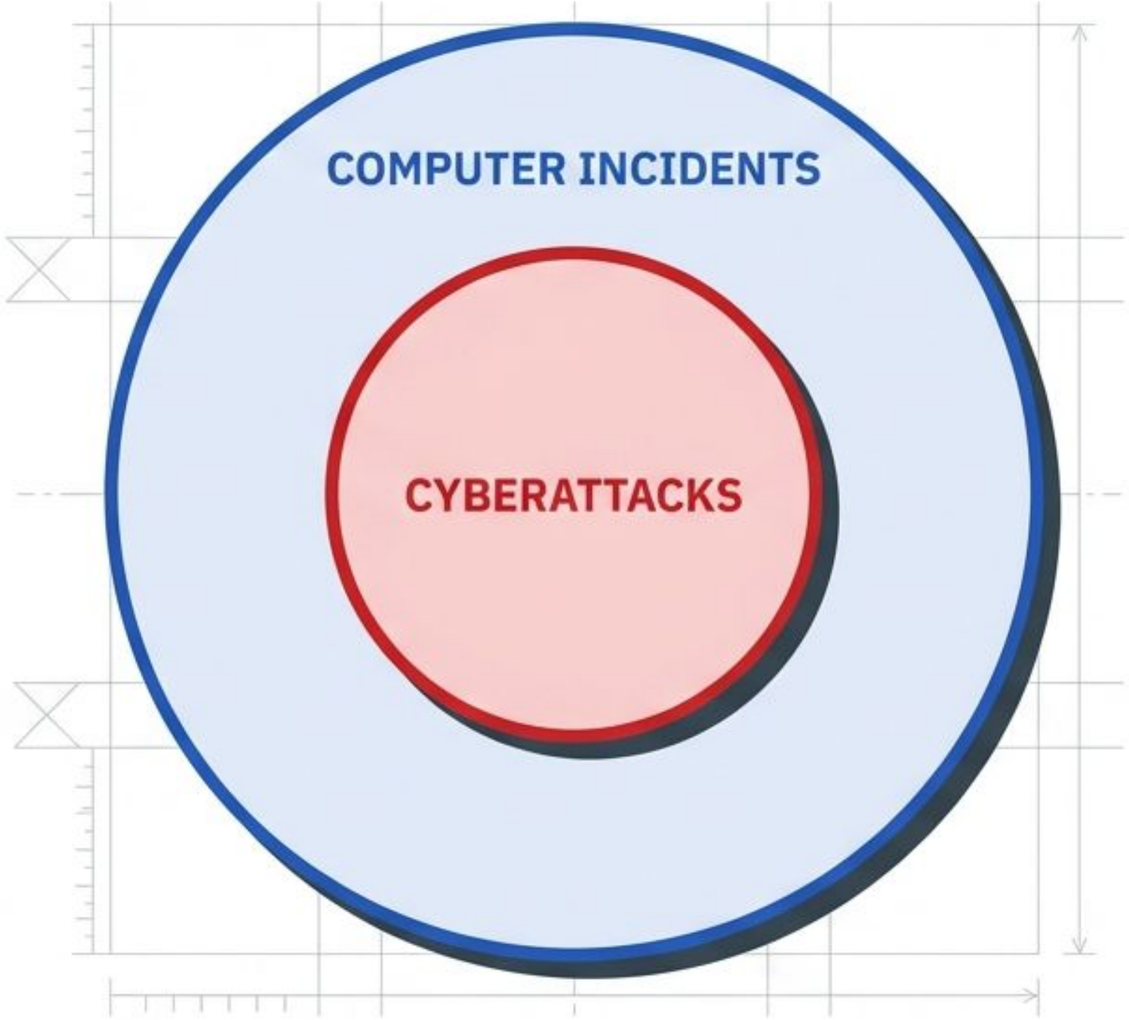
1pt thin

COMPUTER INCIDENT: Any event jeopardizing confidentiality, integrity, or availability.

1pt

CYBERATTACK: A specific, malicious, and intentional incident designed to destroy or steal.

KEY RULE: ALL CYBERATTACKS ARE INCIDENTS, BUT NOT ALL INCIDENTS ARE CYBERATTACKS.



The Adversaries: Threat Actor Profiles

Cybercriminals

Motivated strictly by financial gain.

Nation-States

Driven by political, military, or economic espionage.

Hacktivists

Act on social or political causes, focusing on defacement or leaks.

Insiders

Employees who are malicious or accidental with internal access.

Terrorists

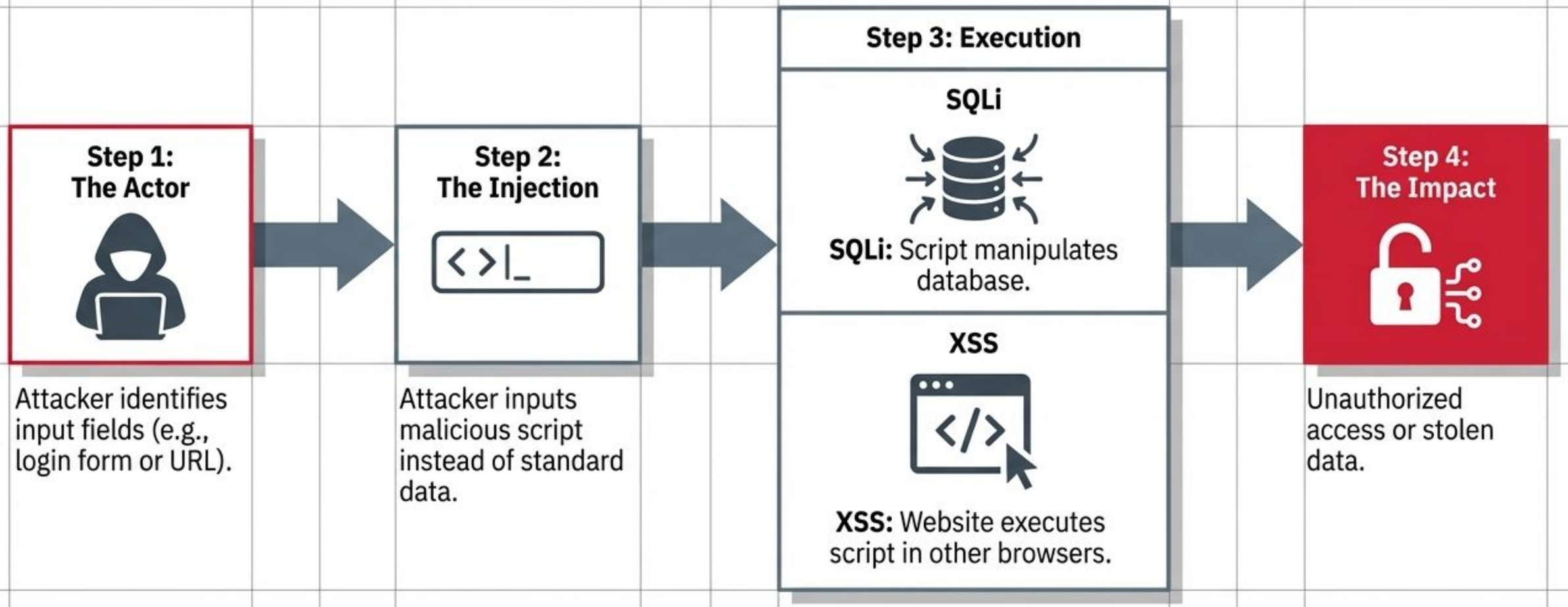
Ideologically motivated to cause disruption to critical infrastructure.

TAXONOMY OF CYBER EXPLOITS

EXPLOITS

- **MALWARE**
  - **WORMS:** Self-replicating, spread without human interaction.
  - **TROJANS:** Disguised as legitimate software to create backdoors.
  - **RANSOMWARE:** Encrypts files, demands payment for decryption.
- **ACCESS & OVERLOAD**
  - **PHISHING:** Fraudulent attempts to steal sensitive data.
  - **DoS / DDoS:** Overwhelming systems to block legitimate users.
  - **PRIVILEGE ESCALATION:** Exploiting flaws for admin access.
- **APPLICATION THREATS**
  - **DRIVE-BY EXPLOITS:** Automatic injection via compromised websites.
  - **PUBLIC-FACING TARGETING:** Attacking vulnerable web servers.

Anatomy of an Exploit: Code Injection



THE CORE SHIELD: THE CIA TRIAD

CONFIDENTIALITY

Prevent unauthorized disclosure via Encryption, Access Controls (RBAC), and Data Classification.

INTEGRITY

Prevent unauthorized alteration via Hashing (SHA-256), Audit Logs, and Input Validation.

AVAILABILITY

Ensure reliable access via Redundancy, Disaster Recovery Plans, and Regular Backups.

Architecting Defense: Implementation Matrix

	Confidentiality	Integrity	Availability
Org Level	• Policies • NDAs • RBAC	• Change management, awareness	• Business Continuity Plans
Network Level	• TLS/SSL • VPNs • Firewalls	• Digital signatures • IDS/IPS	• Redundancy, load balancers
App Level	• Auth management, least privilege	• Input validation, • Parameterized queries	• Horizontal scaling, rate limiting
End-User Level	• MFA, device encryption	• Patching OS, host-based firewalls	• Offline access, lost device reporting

THE COUNTERMEASURE: INCIDENT RESPONSE PHASES

1. NOTIFICATION	2. EVIDENCE	3. CONTAINMENT	4. ERADICATION	5. FOLLOW-UP
Identify incident via alerts or threat feeds.	Create forensic images; secure logs.	Isolate network, apply temporary workarounds.	Remove malware, patch vulnerabilities.	System recovery and root cause analysis.

Operational Strategy: Using an MSSP

MSSP Definition: A third-party provider offering 24/7 remote monitoring and management of security systems.

Advantages

- Cost-Effective (cheaper than internal SOC)
- 24/7 Monitoring & Coverage
- Access to advanced tech and specialized expertise

Disadvantages

- Loss of direct operational control
- Vendor lock-in and transition costs
- Data privacy concerns

Prepared By : Er, Sharat Maharjan

Post-Breach: Computer Forensics

Goal: Determine root cause, gather legally acceptable evidence, and recover data.

1. Identification
Locating evidence sources.

2. Preservation
Isolating evidence to prevent tampering (chain of custody).

3. Analysis
Examining data for timelines and attacker activity.

4. Documentation
Creating repeatable records of all findings.

5. Presentation
Delivering findings in non-technical terms.

Prepared By : Er, Sharat Maharjan

Synthesis: The Cyber Security Ecosystem

A comprehensive architectural schematic of the continuous defense, response, and legal feedback loop.

Phase 1: Exploit Launched

Initial attack vector penetrates defenses.
Vulnerabilities exploited.
System compromised.

Phase 2: The CIA Shield

Defense mechanisms activate. Focus on protecting Confidentiality, Integrity, and Availability.
Preventive controls engaged.

Phase 3: Incident Response

Structured process for detection, analysis, containment, eradication, and recovery. Damage assessed.

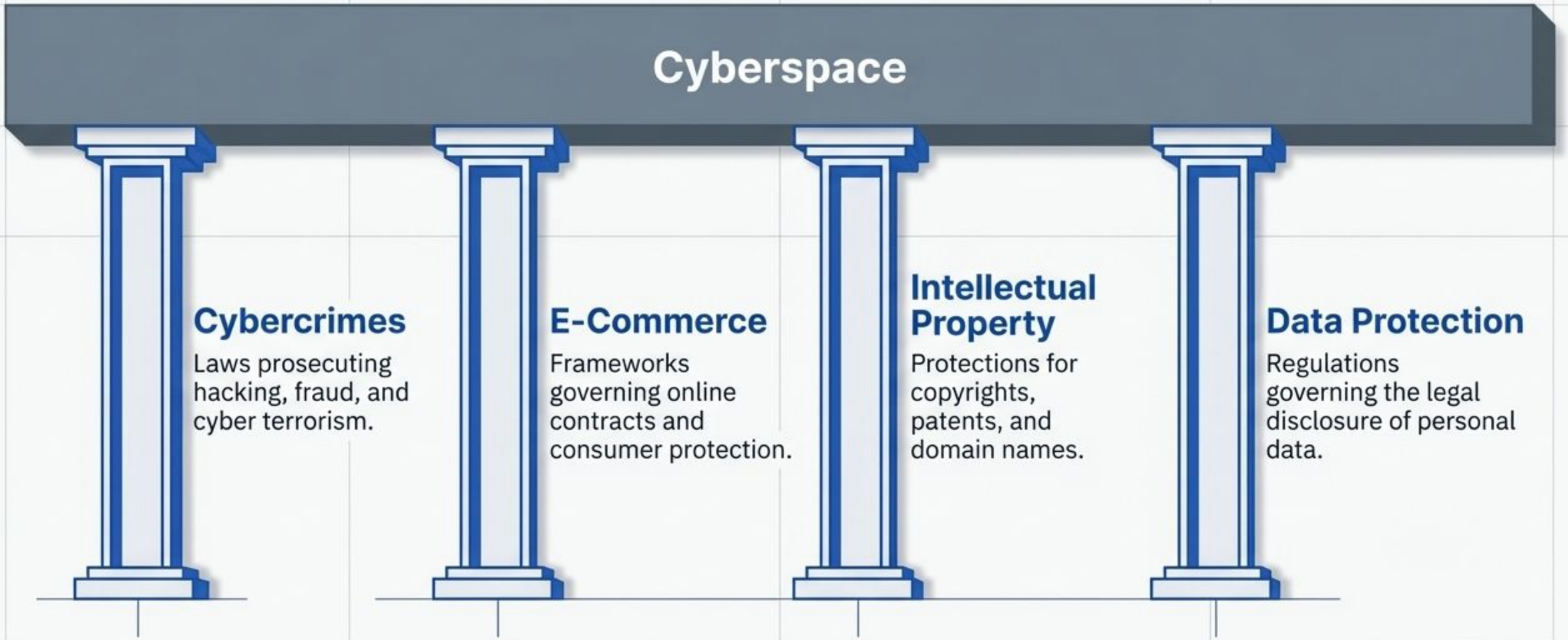
Phase 4: Cyber Law

Legal frameworks applied.
Regulatory compliance (e.g., GDPR, CCPA), reporting, and potential prosecution.
Policy updates.

Prepared By : Er, Sharat Maharjan

The Rule of Law: Cyber Law Fundamentals

A structural framework for the legal governance of the digital domain.



Legal Foundation: Nepal's ETA 2063

The Electronic Transactions Act (ETA), 2063 (2008)

Digital Validity

Grants full legal recognition to records generated in digital formats.

Binding Signatures

Makes digital signatures equivalent to handwritten ones.

Enforcement

Empowers the Nepal Police's Cyber Bureau to investigate offenses.

ETA 2063: Cyber Offenses and Penalties

Crime	Definition	Penalty
Unauthorized Access	Accessing data without authorization	Up to **3 years** & **NPR 200,000** fine
Damage to Systems	Illegally altering information	Up to **3 years** & **NPR 200,000** fine
Publication of Illegal Material	Publishing obscene material electronically	Up to **5 years** & **NPR 100,000** fine
Privacy Breach	Disclosing info without consent	Up to **1 year** & **NPR 50,000** fine

The Horizon: Evolving Legal Frameworks

Individual Privacy Act 2018

Strengthens data protection and collection rules.

Cyber Security Bye-Law 2077 (2020)

Mandates ISPs to establish SOCs and conduct security audits.

Proposed IT & Cyber Security Bill 2080 (2024)

Comprehensive replacement for ETA with strict rules for cloud services.